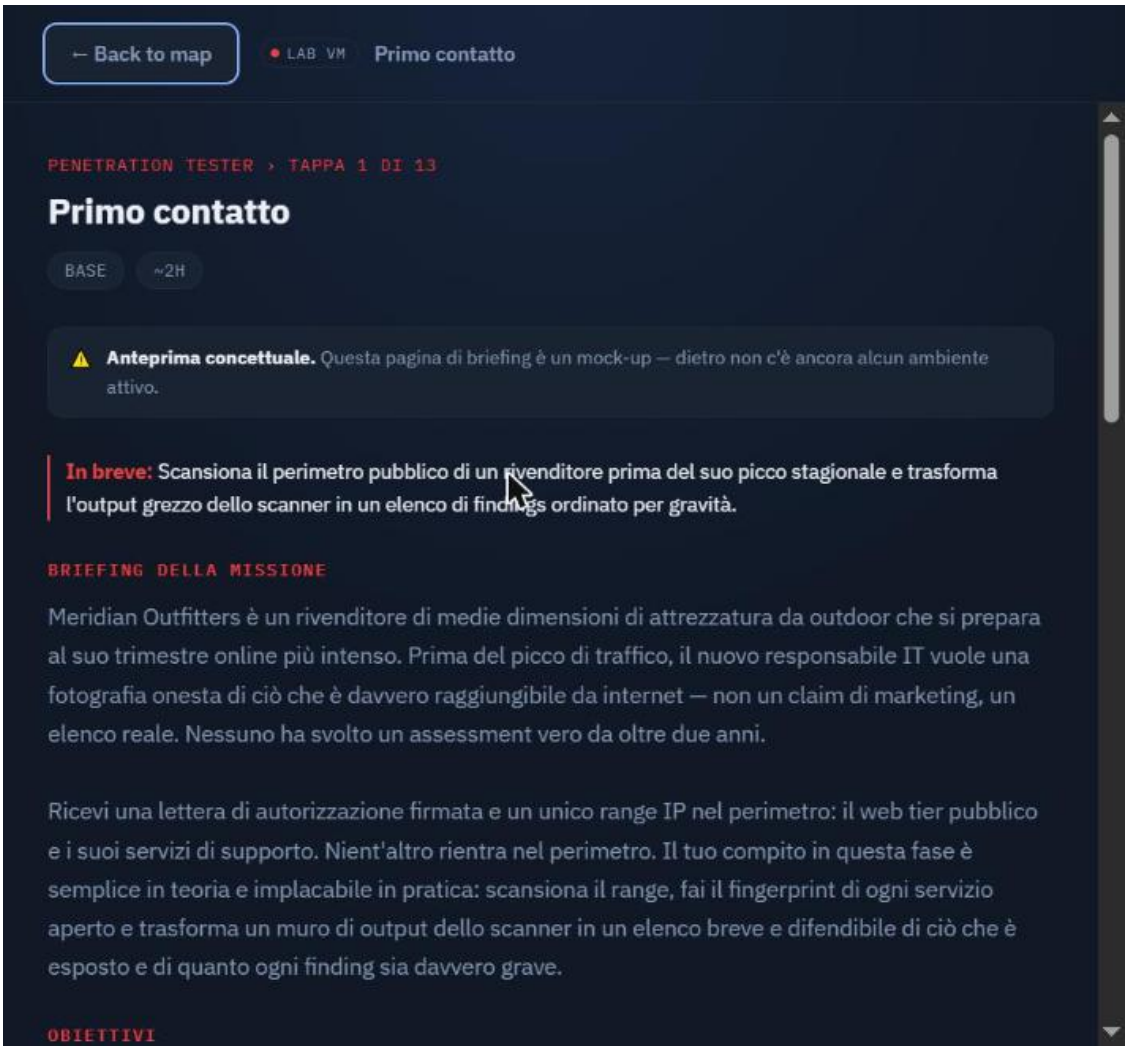
Primo contatto — Explanation

Ruolo: Penetration Tester — tier **va** (Vulnerability Analyst, CREST CPSA)
Lab id: first-contact · **Difficoltà**: Base · **Durata stimata**: ~2.5h-3h
Lab component: lxr:net-perimeter (condiviso con il lab successivo "Come da manuale")

---

1. Schermata del lab (Avvia lab)



Screenshot reale della pagina di briefing così come appare oggi in piattaforma (versione HTB-restyled), con la sezione "In breve" e il briefing della missione. La pagina è un mock-up concettuale: non c'è un ambiente live dietro. Il brief non include dati tecnici già pronti da leggere (banner, versioni, IP): quei dati devono emergere dalla scansione sul proprio ambiente virtuale, non dal testo (vedi sezione 3).

2. Infrastruttura

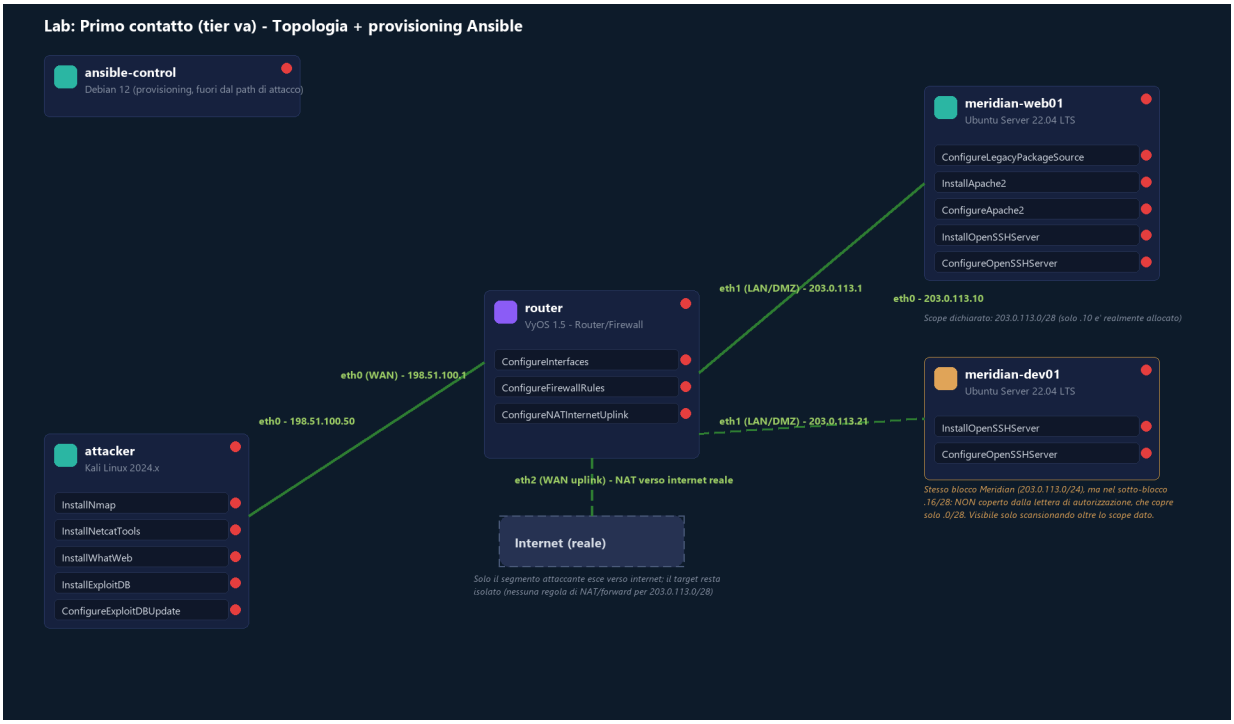
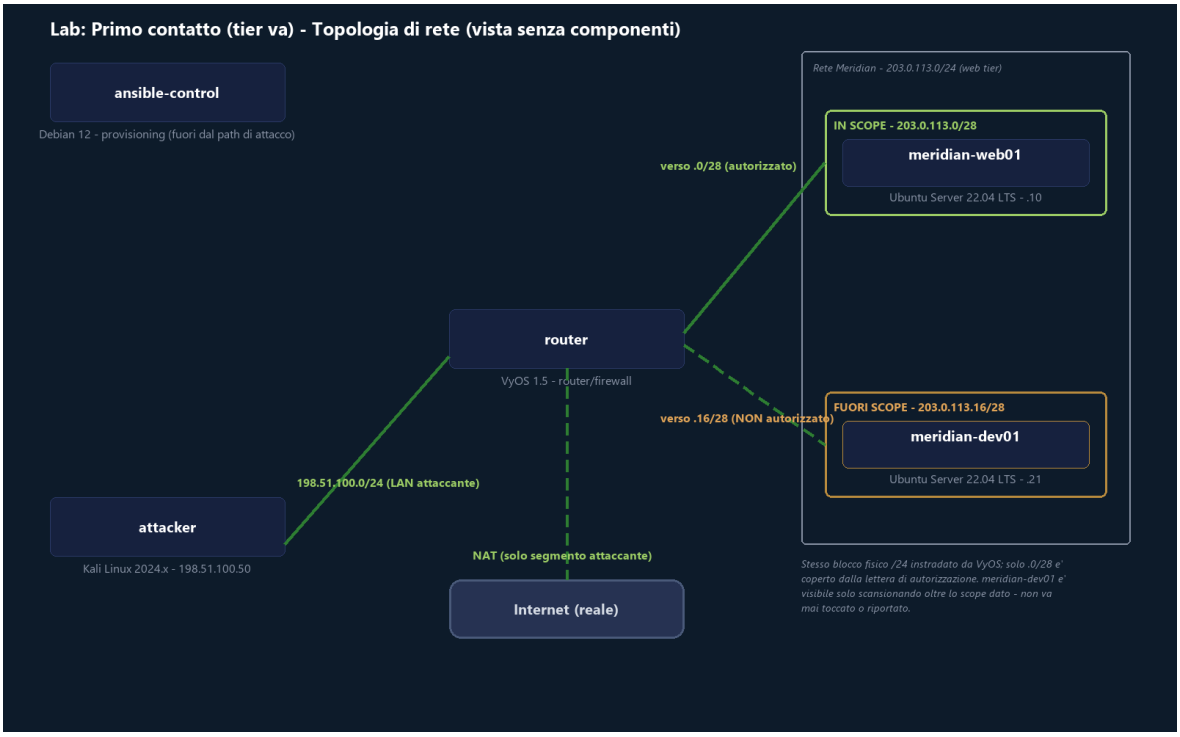


Diagramma sorgente editabile: first-contact-topology.drawio (apribile con draw.io / diagrams.net), nella stessa cartella di questo documento. È disponibile anche una vista equivalente senza i componenti Ansible (solo rete e confine di scope): first-contact-topology-network-only.drawio, riprodotta più sotto.

Gli obiettivi (sezione 4) richiedono di identificare CVE reali, quindi l'attaccante ha un vero accesso a internet (consultazione NVD/exploit-db). VyOS espone una terza interfaccia (eth2, WAN uplink) che fa NAT dal solo segmento attaccante verso l'internet reale. Il segmento target (203.0.113.0/28) resta deliberatamente isolato: nessuna regola di NAT/forward lo collega a internet, coerente con un server legacy dimenticato che nessuno aggiorna più.

Il segmento dell'analista (198.51.100.0/24) è una rete separata da quella del server target, instradata e filtrata da VyOS come qualunque altro segmento della rete aziendale. L'accesso a internet riguarda solo la postazione dell'analista, per la ricerca delle CVE applicabili — non il percorso di scansione verso il server target.

Il blocco 203.0.113.0/24 di Meridian ospita più sotto-reti: la lettera di autorizzazione copre esplicitamente solo 203.0.113.0/28 (meridian-web01). Il sotto-blocco adiacente, 203.0.113.16/28, ospita meridian-dev01 — un sistema reale di un altro team interno, raggiungibile dalla stessa rete instradata da VyOS ma non incluso in questo specifico mandato. Chi scansiona esattamente il blocco autorizzato non lo vede mai; chi scansiona oltre lo scope dato lo trova, ed è tenuto a riconoscerlo come fuori perimetro e a non includerlo in nessun finding.



Vista equivalente senza componenti di provisioning: evidenzia solo la rete e il confine tra ciò che è autorizzato e ciò che non lo è, utile quando il dettaglio Ansible non serve.

3. Perché queste scelte

Storytelling

• **Meridian Outfitters**, rivenditore di medie dimensioni di attrezzatura outdoor, nessun assessment reale da 2+ anni, in arrivo il trimestre più intenso: dà un motivo plausibile e urgente per commissionare *ora* un vulnerability assessment, senza richiedere competenze di exploitation.

• **Scope rigidamente delimitato** (un solo blocco di indirizzi IP, "nient'altro rientra nel perimetro") insegna per prima la disciplina professionale più importante per un VA junior: rispettare lo scope autorizzato, prima ancora di qualunque tecnica. Coerente con l'outcome dichiarato del tier va: *"sai definire il perimetro di un assessment autorizzato, lanciare e leggere gli scanner e trasformare l'output grezzo in un elenco prioritizzato"*. Questo vincolo non è solo narrativo: l'infrastruttura (sezione 2) include un secondo sistema reale, raggiungibile ma deliberatamente fuori da questo mandato, proprio per rendere verificabile se lo studente rispetta lo scope anche quando può tecnicamente vedere oltre.

• **Nessuna exploitation nella trama**: il compito è identificare ed esporre per gravità, mai sfruttare — coerente con CREST CPSA (tier "Practitioner", supervisionato, no exploitation). L'exploitation vera arriva solo dal tier pt in poi (lab "L'ingresso").

• **Arco narrativo con i lab successivi**: "Come da manuale" riprende esplicitamente i finding di questo lab e li traduce in linguaggio da auditor; "La cassetta degli attrezzi" arriva *dopo* ("prima del **prossimo** ingaggio ti serve un toolkit") — prima si lavora con ciò che si ha, poi si professionalizzano gli strumenti prima di passare al vero pentest. Progressione di maturità professionale intenzionale, non un problema di sequencing.

• **Nessuna sezione di "evidenze" già pronte da leggere**: il brief non elenca banner/versioni/IP in una sezione a parte. I dati tecnici devono emergere dalla scansione sul proprio ambiente virtuale, non da un testo che li anticipa — altrimenti le flag diventerebbero un esercizio di lettura, non di analisi. Le flag restano obiettivi di verifica legittimi proprio perché vanno *trovati*, non letti.

Infrastrutturali

• **Ubuntu Server 22.04 LTS come sistema operativo del target**, con Apache e OpenSSH fissati alle versioni vulnerabili richieste dalla narrativa (2.4.18 e 7.2p2) tramite pacchetti .deb storici scaricati dagli archivi Ubuntu e bloccati con apt-mark hold: il sistema operativo è aggiornato, ma questi due servizi non sono mai stati rivisti dopo l'installazione iniziale — lo scenario più realistico (e più comune nei vulnerability assessment reali) di un'azienda che aggiorna l'OS ma perde traccia dei singoli servizi installati sopra.

• **Infrastruttura basata su macchine virtuali reali, non container**: riflette le tecnologie realmente in uso sia sui sistemi interni di Meridian sia sulla postazione dell'analista, non simulazioni leggere.

• **VyOS 1.5 come router e firewall in un solo device** (nessun firewall dedicato separato): VyOS è nativamente anche un firewall stateful zone-based — un singolo edge device che fa routing+firewall è un'architettura reale e comune nelle PMI, coerente con un'azienda poco matura sul fronte security. Un firewall dedicato avrà senso quando la segmentazione stessa sarà parte di un test (es. per il confine IT/OT).

• **Un solo host attivo nel blocco /28 autorizzato**: una scansione sul blocco realmente in scope (203.0.113.0/28) mostra "quasi tutto silenzio, un host con 2 porte" — basta allocare realmente solo l'IP del server target, senza altri host decoy dentro quel blocco.

• **meridian-dev01 nel sotto-blocco adiacente (203.0.113.16/28)**: un secondo host reale, raggiungibile dalla stessa rete instradata da VyOS ma esplicitamente fuori dalla lettera di autorizzazione. Espone solo SSH in configurazione corrente e priva di CVE note, così che non ci sia nulla di "interessante" da trovare anche per chi lo scansiona per curiosità — il punto non è cosa c'è sopra, ma che non va toccato perché fuori mandato.

• **Indirizzamento RFC 5737** (198.51.100.0/24 lato analista, 203.0.113.0/24 lato rete Meridian): blocchi di documentazione reali e non instradabili sull'internet pubblico.

• **Accesso a internet solo dal segmento attaccante**: l'attaccante deve poter consultare CVE reali (NVD/exploit-db), quindi VyOS fa NAT dal solo segmento attaccante verso internet, lasciando l'intera rete Meridian (sia il blocco autorizzato che quello adiacente) isolata dalla rete pubblica.

4. Obiettivi

#	Domanda (flag)	Risposta
1	Quale CVE specifica affligge OpenSSH 7.2p2, permettendo una negazione di servizio pre-autenticazione tramite l'invio di una password eccessivamente lunga?	FLAG{CVE-2016-6515}
2	Secondo NVD, questa CVE è sfruttabile da remoto, senza privilegi né interazione utente, con impatto solo sulla disponibilità (nessun impatto su dati). Quale vettore CVSS v3 base la descrive?	FLAG{AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H}
3	Quale CVE specifica affligge Apache 2.4.17/2.4.18 con mod_http2 abilitato, permettendo una negazione di servizio tramite manipolazione delle finestre di flow-control HTTP/2?	FLAG{CVE-2016-1546}
4	Questa CVE è sfruttabile da remoto, senza privilegi né interazione utente, ma con complessità di attacco alta, e impatto solo sulla disponibilità. Quale vettore CVSS v3 base la descrive?	FLAG{AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H}
5	Convertendo i due vettori CVSS v3 appena derivati nei rispettivi base score numerici (es. tramite il calcolatore ufficiale CVSS v3.0), qual è il base score esatto del servizio da prioritizzare per primo nel report di remediation?	FLAG{7.5}

Mappatura ECSF: Task T1 "Identify, analyse and assess technical and organisational cybersecurity vulnerabilities" · Skill S10 "Decompose and analyse systems to identify weaknesses and ineffective controls" · Knowledge K4 "Operating systems security", K5 "Computer networks security", K10 "Computer systems vulnerabilities".

Perché questi obiettivi

• **Flag 1 e 3 (identificazione della CVE)**: dato un banner di versione, trovare quale vulnerabilità nota si applica esattamente — lavoro investigativo reale (ricerca per prodotto+versione via searchsploit o NVD), non un numero già pubblicato da copiare. Esercita K10 (vulnerabilità note) e T1 (identify/assess) sul serio.

• **Flag 2 e 4 (derivazione del vettore CVSS)**: invece di copiare un punteggio pubblicato, lo studente caratterizza da sé le metriche (AV/AC/PR/UI/S/C/I/A) a partire dai fatti osservati sulla CVE trovata — non aggirabile incollando un numero da un sito esterno, perché richiede di capire cosa significa ogni campo.

• **Flag 5 (sintesi/prioritizzazione)**: richiede di convertire i due vettori appena derivati nei rispettivi base score numerici e di indicare il valore esatto del servizio più critico — non una scelta binaria indovinabile, ma un calcolo possibile solo avendo davvero derivato entrambi i vettori. Esercita S10 e il deliverable del tier (Vulnerability Assessment Results Report).

• **Una sorpresa intenzionale e realistica**: con i dati NVD verificati, la CVE SSH (CVE-2016-6515, vettore con A:H) ha base score 7.5 (High), mentre quella Apache (CVE-2016-1546, vettore con AC:H) ha base score 5.9 (Medium) — il servizio web "sembra" il bersaglio più ovvio perché espone contenuto pubblico, ma la severità verificata dice il contrario. Buona lezione per lo studente: non assumere la gravità solo da quanto un servizio "sembra" esposto.

• Nessuna flag richiede di sfruttare nulla: deliberatamente, per restare dentro i confini del tier va (CREST CPSA, "Practitioner", supervisionato, no exploitation).

• Difficoltà "Base" coerente con un primissimo lab; la durata stimata (~2.5h-3h) tiene conto delle 5 flag (identificazione CVE + derivazione vettore CVSS per due servizi, più la sintesi finale).

5. Tool, OS e configurazioni

Componente	OS / Tecnologia	Install	Configure

meridian-web01 (target, in scope)	Ubuntu Server 22.04 LTS	Apache2, OpenSSH Server	ConfigureLegacyPackageSource, ConfigureApache2, ConfigureOpenSSHServer
meridian-dev01 (fuori scope)	Ubuntu Server 22.04 LTS	OpenSSH Server	ConfigureOpenSSHServer
router	VyOS 1.5	— (OS già completo)	ConfigureInterfaces, ConfigureFirewallRules, ConfigureNATInternetUplink
attacker	Kali Linux 2024.x	nmap, netcat/ncat, whatweb, searchsploit (exploitdb)	ConfigureExploitDBUpdate
ansible-control	Debian 12	ansible-core	— (è il controller)

Perché proprio questi tool/OS/configurazioni

• **ConfigureLegacyPackageSource**: scarica i pacchetti .deb storici di Apache 2.4.18 e OpenSSH 7.2p2 dagli archivi Ubuntu (non più presenti nei repository correnti di una 22.04) e li blocca con apt-mark hold dopo l'installazione, così che un aggiornamento successivo del sistema non li sovrascriva.

• **meridian-dev01 con OpenSSH di versione corrente, senza pin**: a differenza del target, qui non c'è nessuna versione specifica da riprodurre — il punto di questo host è essere un sistema reale ma irrilevante ai fini del mandato, non un secondo obiettivo nascosto.

• **Configure esplicite su Apache/SSH, non lasciate ai default di apt**: il banner deve restare esattamente quello previsto. Fissare ServerTokens/ServerSignature e sshd_config via Ansible garantisce che il server mostri sempre, in modo deterministico, queste esatte versioni.

• **nmap / ncat / whatweb / searchsploit sull'attacker**: toolset minimo realistico di un VA per questo compito. Nessun tool di exploitation (niente Metasploit/Burp/sqlmap): fuori scope per il tier va.

• **ConfigureExploitDBUpdate**: un analista reale aggiorna il mirror locale delle CVE prima di affidarsi a searchsploit — passo di configurazione reale, non simmetria estetica.

• **VyOS come router+firewall unico**: motivato in dettaglio nella sezione 3 (Infrastrutturali).

• **ConfigureNATInternetUplink**: l'attaccante deve poter consultare CVE reali, quindi VyOS fa NAT dal solo segmento attaccante verso internet, lasciando il target completamente isolato dalla rete pubblica.

• **Ansible per il provisioning**: garantisce che target e router vengano configurati sempre nello stesso modo, in maniera deterministica e senza intervento manuale.

6. Playbook section

Da completare. Qui andranno elencati i playbook Ansible effettivi (uno per componente o un playbook unico con ruoli separati), con il percorso del repository e la mappatura ruolo → task Ansible.

7. Lab solution

1. Verifica dello scope

Il blocco da testare (203.0.113.0/28) non si scopre tecnicamente: è scritto nella lettera di autorizzazione che Meridian consegna prima dell'inizio dell'assessment — un dato di contesto ricevuto, non un risultato di ricognizione. Prima di scansionare qualunque cosa, si conferma che quel blocco è esattamente ciò che l'autorizzazione copre, e che nient'altro è in scope.

Da notare che l'analista non si trova fisicamente su quella rete: la propria postazione ha un indirizzo su un segmento separato, e il traffico verso 203.0.113.0/28 viene instradato dal gateway fino al segmento del server target — esattamente come un analista che lavora da remoto raggiunge la rete di un cliente attraverso l'accesso che il cliente stesso gli fornisce.

La rete di Meridian raggiungibile da quel gateway è però più ampia del solo blocco autorizzato: l'autorizzazione copre esplicitamente 203.0.113.0/28 e nient'altro. Qualunque sistema si trovi al di fuori di quell'intervallo, anche se tecnicamente raggiungibile, resta fuori mandato per definizione, a prescindere da quanto sembri interessante.

2. Discovery sul blocco autorizzato

```
nmap -sn 203.0.113.0/28
```

Risultato atteso: silenzio quasi ovunque, un solo host vivo — 203.0.113.10. Scansionare esattamente l'intervallo autorizzato, né più né meno, è la scelta corretta: un comando più largo (es. `nmap -sn 203.0.113.0/24`) avrebbe fatto emergere anche 203.0.113.21 — un secondo host reale (meridian-dev01), fuori però dalla lettera di autorizzazione. Se dovesse comparire per errore, la risposta corretta è ignorarlo: non va scansionato ulteriormente, né incluso nel report finale.

3. Scansione di servizio con version detection

```
nmap -sV -p- 203.0.113.10
```

Risultato: solo due porte aperte — 22 (OpenSSH 7.2p2 Ubuntu-4ubuntuX.Y) e 80 (Apache httpd 2.4.18 (Ubuntu)). Nient'altro.

4. Conferma manuale dei banner

```
nc -v 203.0.113.10 22
curl -I http://203.0.113.10/
```

5. Flag 1 — identificazione CVE su SSH

```
searchsploit openssh 7.2
```

Emerge CVE-2016-6515: DoS pre-autenticazione tramite invio di una password eccessivamente lunga (consumo CPU in auth-passwd.c), affligge le versioni fino alla 7.2 inclusa → **FLAG{CVE-2016-6515}**.

6. Flag 2 — vettore CVSS su quella CVE

Da NVD per CVE-2016-6515: sfruttabile da remoto (AV:N), bassa complessità (AC:L), nessun privilegio richiesto (PR:N) perché avviene durante il tentativo di login stesso, nessuna interazione utente (UI:N), nessun impatto su dati (C:N/I:N), solo disponibilità, valutata Alta (A:H) → **FLAG{AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H}** (base score 7.5, High).

7. Flag 3 — identificazione CVE su Apache

```
searchsploit apache 2.4.18
```

Emerge CVE-2016-1546: DoS tramite manipolazione delle finestre di flow-control HTTP/2, affligge specificamente le versioni 2.4.17 e 2.4.18 con mod_http2 abilitato → **FLAG{CVE-2016-1546}**.

8. Flag 4 — vettore CVSS su quella CVE

Da NVD: remoto (AV:N), ma complessità alta (AC:H) perché richiede di orchestrare con precisione le finestre di flow-control, nessun privilegio/interazione richiesti, solo impatto sulla disponibilità → **FLAG{AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H}** (base score 5.9, Medium).

9. Flag 5 — prioritizzazione

Convertendo i due vettori appena derivati in punteggio numerico tramite il calcolatore ufficiale CVSS v3.0: SSH (CVE-2016-6515) risulta 7.5 (High), Apache (CVE-2016-1546) risulta 5.9 (Medium). Nonostante Apache "sembri" il bersaglio più ovvio (espone contenuto pubblico), il dato verificato dice che SSH ha l'impatto più alto → **FLAG{7.5}**.

10. Report finale

Tabella findings → CVE → CVSS → raccomandazione: patchare prima OpenSSH (porta 22, severità 7.5 High), poi Apache (porta 80, 5.9 Medium). Entrambe le vulnerabilità sono DoS puro, nessuna RCE: il rischio è di disponibilità, non di confidenzialità dei dati.